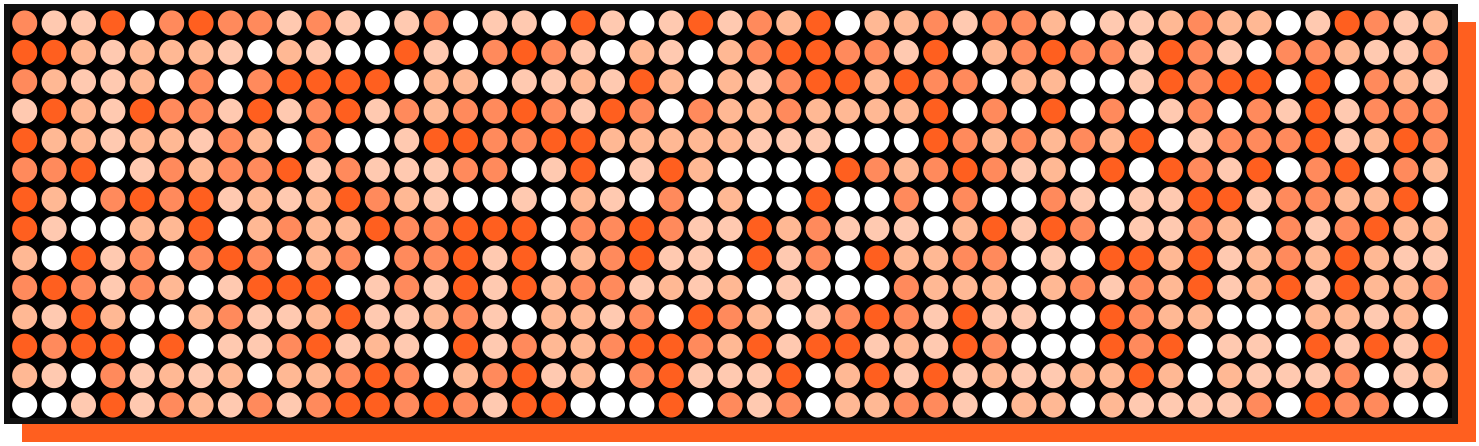
PAPYRUS EVIDENCE PACK

SUPPLY-CHAIN EVIDENCE

Image digests, signatures, build provenance, SBOMs and vulnerability scans for this release.



RELEASE **0.1.0+3e23d44**	BUILT **2026-10-27T15:00:32Z**
IMAGE **ghcr.io/beaglabs/papyrus/papyrus**	INDEX DIGEST **sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d**

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

CONTAINER SUPPLY-CHAIN EVIDENCE

Evidence for the published Papyrus image `ghcr.io/beaglabs/papyrus/papyrus@sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d`, built from revision `3e23d4432d3e52dda99c433ee48e3d702896e63c` on 2026-10-27T15:00:32Z. Every item below was produced or checked by tools against that digest; the commands to repeat each check are at the end.

IMAGE

PLATFORM	MANIFEST DIGEST	CREATED	USER	LAYERS	SBOM COMPONENTS
linux/amd64	`sha256:acf7f65e70bf5b107fce73ee73b8430c1b1c510383851b933766d38a17e031ee`	2026-10-27T15:02:02.520272175Z	65532:65532	10	883
linux/arm64	`sha256:0ccbe9d7755d7daf1b430abcc084935bb171c88c918f7aefd0b8f7cf4bb9ed9c`	2026-10-27T15:00:32.852842981Z	65532:65532	10	883

SIGNATURE

The multi-arch index is signed keylessly with Sigstore cosign by GitHub Actions and recorded in the Sigstore public-good Rekor transparency log. Verification passed for workflow identity `^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?\.yml@refs/heads/main$` from issuer `https://token.actions.githubusercontent.com`, at workflow revision `3e23d4432d3e52dda99c433ee48e3d702896e63c` on `refs/heads/main`.

BUILD PROVENANCE

A `https://slsa.dev/provenance/v1` attestation for the index digest was verified: signed by `https://github.com/beaglabs/papyrus/.github/workflows/container-multiarch.yml@refs/heads/main` on a github-hosted runner from source `3e23d4432d3e52dda99c433ee48e3d702896e63c`. The source repository is private, so the attestation is signed through GitHub Sigstore (private repository); the Sigstore bundle is published in this pack so it can be verified without repository access.

VULNERABILITY SCAN

Scanned with Trivy 0.72.0 using the vulnerability database updated 2026-10-26T19:14:50.196574068Z. Counts are findings, with the number that have a fixed version available in brackets. A scan is a point-in-time result; rescan the digest for current findings.

PLATFORM	CRITICAL	HIGH	MEDIUM	LOW
linux/amd64	0 (0)	0 (0)	2 (2)	2 (2)
linux/arm64	0 (0)	0 (0)	2 (2)	2 (2)

SOFTWARE BILL OF MATERIALS

Each platform has a CycloneDX and an SPDX SBOM generated from the image itself, so they include operating system packages and every transitive Node.js and Python dependency in the shipped filesystem. Timestamps and serial numbers are pinned to the image so repeated runs produce identical documents.

HOW TO VERIFY

SIGNATURE (COSIGN 2.4+)

```
cosign verify --certificate-identity-regexp '^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?
\.yml@refs/heads/main$' --certificate-oidc-issuer https://token.actions.githubusercontent.com
ghcr.io/beaglabs/papyrus/papyrus@sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d
```

PROVENANCE (GITHUB CLI 2.60+, RUN FROM THIS PACK'S FOLDER)

```
gh attestation verify oci://ghcr.io/beaglabs/papyrus/papyrus@sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d --bundle
supply-chain/provenance.sigstore.json --repo beaglabs/papyrus
```

SBOM AND SCAN (TRIVY)

```
trivy image --format cyclonedx ghcr.io/beaglabs/papyrus/papyrus@<platform digest>
```

FILES

FILE	SHA-256
sbom/papyrus-linux-amd64.cdx.json	d9d5416f7417f45d89187f1d68a5945e8ce4770a6089efccd8f3c6fb47c9a626
sbom/papyrus-linux-amd64.spdx.json	ce68976fa4b29c099d609ef9c273716d3040a90620f147925edf16f5eb77a551
sbom/papyrus-linux-arm64.cdx.json	f5f5a08d779e92d2e81b80f0a8db970b4b94e9269fbbcad680028507e51bdf0f
sbom/papyrus-linux-arm64.spdx.json	fd5913a61b4c720a09661d5b2543b2843c9a6f331205909df1e44cc570e474fb
supply-chain/image-index.json	1ac55a2e21466d9a3c391262d25228b404ae6766ec28d0a585724c230604772b
supply-chain/provenance-verification.json	6e98e9c4e1fbfa504b15b94db100d2433d250f36112a3966f99b7c4d23faf93c
supply-chain/provenance.sigstore.json	36c1dac1792ee9924b025a595c23b0eea3aa3b2bfaf9703efe83220f93b986d8
supply-chain/signature-verification.json	b57bf8c8cf11e2ef2bd232f04e36e9ceff6d13b0c44aef054bda40c51ead9550
supply-chain/vulnerabilities-linux-amd64.json	1d0c8ef5e00a0d52987e8f840478f3b22ca44f7baf0507870fabbb3ee142288c
supply-chain/vulnerabilities-linux-arm64.json	41447e4319ad7fa55a3c55eff0ba059aed90e332019b57cb7e31dfe14b3cc11e